AI EXPONENT LLC

EU AI Act Article 9 Risk Management File

Retail Credit Risk Scorer

Version 1.0.0

28	14	8
risk items	open above appetite	knowledge gaps

Provider	Northwind Scoring Labs (fictional)
Assessor	Mara Lindqvist, Head of Model Risk
Assessment date	07 November 2026
Review date	07 November 2027
Annex III category	Essential Services
Readiness gates	Exported with failing gates: G3

Content digest (SHA-256)

`55c7cb191f3775a63d61c889c6f96d9681ef0753a813fc9916a43bc5fd344827`

1. Executive summary

Purpose: Credit scoring of retail consumer credit applicants: a binary classifier, trained on the UCI Statlog German Credit data, scores each applicant as good or bad credit risk, and a lender's credit officer uses the score when deciding on the application.

Annex III category: Essential Services

Self-classification documented: Yes

Risk items: 28 in total. Before treatment, 16 scored above the risk appetite threshold of 9; after treatment, 14 remain open.

Knowledge gaps: 8

System description

Field	Value
System ID	`4f9e10da-5529-40a6-84e8-144190ab742c`
Name	Retail Credit Risk Scorer
Version	1.0.0
Provider	Northwind Scoring Labs (fictional)
Provider contact	*Not specified*
Intended users	*Not specified*
Inputs	*Not specified*
Outputs	*Not specified*
Deployment context	*Not specified*

This document was produced using RiskForge v2.1.0, question bank version 1.0.0. It represents the team's documented risk assessment and has not been reviewed by a qualified legal professional. It does not constitute legal advice under the EU AI Act or any other regulation.

2. Methodology

The assessment uses the RiskForge question bank, version 1.0.0, across 8 risk dimensions: health safety, fundamental rights, discrimination, privacy, transparency, human oversight, robustness, data governance.

Each risk is scored for likelihood and severity on a five-point scale. The risk score is likelihood times severity, from 1 to 25. Bands: low 1 to 4, medium 5 to 9, high 10 to 16, critical 17 to 25. Likelihood and severity are scored again after mitigation to give the residual score.

A risk is open while its residual score is above the risk appetite threshold of 9 and it has not been accepted with a written rationale. Gate G3 fails while any risk is open.

Risk patterns applied: CREDIT_SCORING_BIAS.

Readiness gates G1 to G8 are the checks `riskforge validate` runs. A FAIL gate blocks export unless the export is forced. Results at export:

G1 PASS, **G2 PASS**, **G3 FAIL**, **G4 PASS**, **G5 WARN**, **G6 PASS**, **G7 PASS**, **G8 PASS**

3. Risk register

Risk appetite threshold: 9 (residual scores above it need mitigation or acceptance).

3.1 Health safety

Production performance not monitored for degradation HIGH (12)

Question HS-005: Are system performance metrics (accuracy, error rates, latency) monitored in production with alerts for degradation? Post-market monitoring under Article 72 requires tracking of actual performance against stated specifications.

Likelihood	Likely (4)	**Severity**	Moderate (3)
Residual likelihood	Likely (4)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(8), Art.72

NIST AI RMF: MEASURE 2.4 | ISO/IEC 42001: Clause 9.1

Mitigations:

- **Detective** [planned]: Track approval rate, observed bad rate at 12 months and cost-weighted error each month against the validation values, with an alert at a 20 percent relative change.

Recorded by: Mara Lindqvist, Head of Model Risk

System errors may harm vulnerable groups disproportionately

HIGH (12)

Question HS-006: Could vulnerable populations (elderly, children, people with disabilities) be disproportionately harmed by system errors? Article 9(9) requires explicit consideration of impacts on children and other vulnerable groups.

Likelihood	Possible (3)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(9)

NIST AI RMF: MAP 5.1 | ISO/IEC 42001: Clause 6.1

Mitigations:

- **Detective** [planned]: Report error rates and cost-weighted error by age band (under 25, 25 to 59, 60 and over) at each release and block release if a band is worse than the overall rate by more than 10 percent.

Recorded by: Mara Lindqvist, Head of Model Risk

3.2 Fundamental rights

No fundamental rights impact assessment before deployment

MEDIUM (9)

Question FR-001: Has a fundamental rights impact assessment (FRIA) been conducted prior to deployment? Article 9(2)(a) requires identification of known and foreseeable risks to fundamental rights. A FRIA is the standard mechanism for this.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(2)(a)

NIST AI RMF: GOVERN 1.1 | ISO/IEC 42001: Clause 6.1

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the default, likelihood 3 and severity 3, until it is assessed. Its test requirements are listed in section 5.

System may restrict access to rights under the EU Charter of Fundamental Rights

HIGH (12)

Question FR-002: Could the system restrict or affect access to rights protected under the EU Charter of Fundamental Rights? Consider right to an effective remedy, right to a fair trial, presumption of innocence, freedom of expression, right to education.

Likelihood	Possible (3)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(2)(a)

NIST AI RMF: MAP 5.1 | ISO/IEC 42001: Clause 6.1

Mitigations:

- **Corrective** [planned]: State in the instructions for use that a refused applicant can ask for a second review by a credit officer who did not make the first decision, and that the score alone must not refuse an application.

Recorded by: Mara Lindqvist, Head of Model Risk

Affected people not told of the AI system's role in decisions about them

MEDIUM (6)

Question FR-003: Are affected individuals informed of the AI system's role in decisions that affect them, in a language they understand? Transparency is a foundational right. The obligation to inform subjects is strengthened in high-risk AI contexts.

Likelihood	Unlikely (2)	**Severity**	Moderate (3)
Residual likelihood	Unlikely (2)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.26(11)

NIST AI RMF: MEASURE 2.8 | ISO/IEC 42001: Annex A.6

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the question's hint, likelihood 2 and severity 3, until it is assessed. Its test requirements are listed in section 5.

3.3 Discrimination

Demographic bias in credit scoring outputs

HIGH (12)

Credit scoring models trained on historical data may encode systemic biases against protected groups (age, gender, ethnicity). Article 9(9) requires consideration of impacts on vulnerable groups.

Likelihood	Possible (3)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Pattern	**Regulatory status**	Settled

Article refs: Art.9(2)(a), Art.9(9), Art.10(2)(f)

NIST AI RMF: MEASURE 2.11 | ISO/IEC 42001: Annex A.7

Mitigations:

- **Detective** [planned]: Apply the release gate on demographic parity and equal opportunity difference (above 0.10 blocks release) by sex, age band and foreign worker flag.

Recorded by: Mara Lindqvist, Head of Model Risk

Training data not audited for representation imbalance across protected groups

HIGH (16)

Question DI-001: Has the training dataset been audited for representation imbalances across protected characteristics (gender, ethnicity, age, disability)? Biased training data produces biased outputs. Article 10(2)(f) requires data governance measures to address biases.

Likelihood	Likely (4)	**Severity**	Major (4)
Residual likelihood	Likely (4)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.10(2)(f), Art.9(2)(a)

NIST AI RMF: MEASURE 2.11 | ISO/IEC 42001: Annex A.7

Mitigations:

- **Detective** [implemented]: Report record counts and the share of bad class by the sex part of attribute 9, by age band (under 25, 25 to 59, 60 and over) and by foreign worker flag, and state that married and divorced women share one code.

Recorded by: Mara Lindqvist, Head of Model Risk

Fairness metrics not computed for each protected group

HIGH (16)

Question DI-002: Have demographic parity, equalised odds, or other fairness metrics been computed and documented for each protected group? Quantified fairness metrics are required for meaningful bias assessment. Select metrics appropriate to the use case.

Likelihood	Likely (4)	**Severity**	Major (4)
Residual likelihood	Likely (4)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(8), Art.10(2)(f)

NIST AI RMF: MEASURE 2.11 | ISO/IEC 42001: Annex A.7

Mitigations:

- **Detective** [planned]: Compute demographic parity difference and equal opportunity difference by sex, age band and foreign worker flag on the hold-out set; block release if any difference is above 0.10.

  Recorded by: Mara Lindqvist, Head of Model Risk

Proxy variables may encode protected characteristics

CRITICAL (20)

Question DI-003: Does the system use proxy variables that may correlate with protected characteristics (e.g. postcode, school name, employment gaps)? Proxy discrimination occurs when facially neutral features encode protected characteristics. Legal exposure exists even without intent.

Likelihood	Almost certain (5)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(2)(a), Art.10(2)(f)

NIST AI RMF: MEASURE 2.11 | ISO/IEC 42001: Annex A.7

Mitigations:

- **Preventive** [implemented]: Remove attributes 9 (personal status and sex), 13 (age) and 20 (foreign worker) from the model inputs. Keep them in a separate table used only for bias testing.

  Recorded by: Mara Lindqvist, Head of Model Risk

- **Detective** [planned]: Measure the association of each remaining input with sex, age band and foreign worker status on the 1000 records, and drop or bin any input with Cramer's V above 0.3.

  Recorded by: Mara Lindqvist, Head of Model Risk

Bias tests not repeated at each model update

MEDIUM (6)

Question DI-004: Are bias test results documented and reviewed at each model update, not just at initial deployment? Data drift and concept drift can re-introduce bias after initial mitigation. Continuous monitoring is required.

Likelihood	Unlikely (2)	**Severity**	Moderate (3)
Residual likelihood	Unlikely (2)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(8), Art.72

NIST AI RMF: MEASURE 2.11 | ISO/IEC 42001: Clause 9.1

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the question's hint, likelihood 2 and severity 3, until it is assessed. Its test requirements are listed in section 5.

3.4 Privacy

System processes personal or special category data

CRITICAL (20)

Question PR-001: Does the system process personal data or special category data (health, biometric, ethnicity, religion)? Processing of special category data triggers additional obligations under GDPR Article 9. EU AI Act Article 4a(1) allows providers of high-risk AI systems to process special categories of personal data exceptionally, to the extent strictly necessary to ensure bias detection and correction.

Likelihood	Almost certain (5)	**Severity**	Major (4)
Residual likelihood	Almost certain (5)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.4a(1)

NIST AI RMF: MEASURE 2.10 | ISO/IEC 42001: Annex A.7

Mitigations:

- **Preventive** [planned]: Record the legal basis for using the 1994 records and live applicant data, agreed with the lender's data protection officer, and list the personal data each input carries.

  Recorded by: Mara Lindqvist, Head of Model Risk

No Data Protection Impact Assessment carried out

MEDIUM (9)

Question PR-002: Has a Data Protection Impact Assessment (DPIA) been carried out, with the advice of the Data Protection Officer where one is designated? GDPR Article 35 requires a DPIA for high-risk processing. High-risk AI systems typically trigger this threshold.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.26(9), Art.9(2)(a)

NIST AI RMF: MEASURE 2.10 | ISO/IEC 42001: Annex A.7

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the default, likelihood 3 and severity 3, until it is assessed. Its test requirements are listed in section 5.

Model uses more personal data than its purpose needs

HIGH (12)

Question PR-003: Is data minimisation enforced: does the model use only the minimum personal data necessary for the intended purpose? GDPR data minimisation and purpose limitation principles (GDPR Article 5(1)(b) and (c)) apply to AI systems processing personal data.

Likelihood	Likely (4)	**Severity**	Moderate (3)
Residual likelihood	Unlikely (2)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

NIST AI RMF: MEASURE 2.10 | ISO/IEC 42001: Annex A.7

Mitigations:

- **Preventive** [implemented]: Remove attribute 19 (telephone) as well as attributes 9, 13 and 20 from the model inputs, and document why each remaining input is needed.

Recorded by: Mara Lindqvist, Head of Model Risk

Personal data in training data not found and redacted or pseudonymised

MEDIUM (6)

Question PR-004: Has the training data been scanned for inadvertent PII inclusion, and is PII redaction/ pseudonymisation applied before training? Training data containing real PII creates privacy risk. Automated PII detection tools (e.g. TraceForge) can surface this.

Likelihood	Unlikely (2)	**Severity**	Moderate (3)
Residual likelihood	Unlikely (2)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

NIST AI RMF: MEASURE 2.10 | ISO/IEC 42001: Annex A.7

3.5 Transparency

Lack of explanation for credit decisions

MEDIUM (9)

Where a solely automated credit decision falls under GDPR Article 22(2)(a) or (c), GDPR Article 22(3) gives at least the right to obtain human intervention, to express a point of view and to contest the decision, and GDPR Articles 13(2)(f), 14(2)(g) and 15(1)(h) require meaningful information about the logic involved. The system may not currently support this.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Pattern	**Regulatory status**	Settled

Article refs: Art.13, Art.86(1)

NIST AI RMF: MEASURE 2.8 | ISO/IEC 42001: Annex A.6

Mitigations:

- **Preventive** [planned]: Return the four inputs that contributed most to each score as reason codes, for the lender to pass to the applicant on request.

Recorded by: Mara Lindqvist, Head of Model Risk

Users not told they are interacting with or assessed by an AI system

MEDIUM (9)

Question TR-001: Are users notified that they are interacting with or being assessed by an AI system? Article 26(11) requires deployers of Annex III high-risk AI systems that make or assist in making decisions related to natural persons to inform them that they are subject to the use of the system. Article 50(1) covers informing natural persons that they are interacting with an AI system.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.26(11), Art.50(1)

NIST AI RMF: MEASURE 2.8 | ISO/IEC 42001: Annex A.6

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the default, likelihood 3 and severity 3, until it is assessed. Its test requirements are listed in section 5.

No explanation of the decision logic available to affected people

HIGH (12)

Question TR-002: Is an explanation of the system's decision-making logic available to affected individuals upon request? GDPR Article 22(1) gives a right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects or similarly significantly affects the person. GDPR Articles 13(2)(f), 14(2)(g) and 15(1)(h) require meaningful information about the logic involved. An explanation capability is a key technical control.

Likelihood	Possible (3)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.13(3)(b)(iv), Art.86(1)

NIST AI RMF: MEASURE 2.8 | ISO/IEC 42001: Annex A.6

Mitigations:

- **Preventive** [planned]: Return the four inputs that contributed most to each score as reason codes, for the lender to pass to the applicant on request.

Recorded by: Mara Lindqvist, Head of Model Risk

Documentation omits capability limitations and known failure modes

MEDIUM (9)

Question TR-003: Does the system documentation include clear capability limitations, known failure modes, and out-of-distribution behaviour? Article 13(3)(b) requires information about the system's capabilities and limitations for the benefit of deployers.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Unlikely (2)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.13(3)(b)

NIST AI RMF: MEASURE 2.8 | ISO/IEC 42001: Annex A.6

Mitigations:

- **Preventive** [implemented]: Add a limitations section to the instructions for use: the training data is from 1994 and in DM, the collection and the meaning of good and bad are not documented, representativeness is unknown, and code A47 is uncertain.

Recorded by: Mara Lindqvist, Head of Model Risk

3.6 Human oversight

Reviewers not trained on the system's capabilities, limitations and known biases

MEDIUM (9)

Question HO-002: Are human reviewers trained on the system's capabilities, limitations, and known biases before making decisions based on its output? Untrained human reviewers provide illusory oversight. Article 26(2) requires deployers to assign human oversight to natural persons who have the necessary competence, training and authority.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.26(2)

NIST AI RMF: MAP 3.5 | ISO/IEC 42001: Annex A.9

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the question's hint, likelihood 3 and severity 3, until it is assessed. Its test requirements are listed in section 5.

Review workload too high for meaningful human oversight

HIGH (12)

Question HO-003: Is the human oversight load (volume of cases reviewed per reviewer per day) realistic for meaningful review, not rubber-stamping? Automation bias and review fatigue cause human oversight to become nominal. Workload design is a technical control.

Likelihood	Possible (3)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.14

NIST AI RMF: MAP 3.5 | ISO/IEC 42001: Annex A.9

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the question's hint, likelihood 3 and severity 4, until it is assessed. Its test requirements are listed in section 5.

System reasoning not interpretable to human reviewers

HIGH (12)

Question HO-004: Is the system designed to make its reasoning interpretable to human reviewers (e.g. via explainability methods, confidence scores, supporting evidence)? Human oversight is only meaningful if the reviewer can understand what the system decided and why.

Likelihood	Possible (3)	**Severity**	Major (4)
Residual likelihood	Possible (3)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.14(4)(c)

NIST AI RMF: MEASURE 2.9 | ISO/IEC 42001: Annex A.6

Mitigations:

- **Preventive** [planned]: Show the credit officer the reason codes and the score band next to each score.

Recorded by: Mara Lindqvist, Head of Model Risk

3.7 Robustness

Not tested on out-of-distribution, edge-case and adversarial inputs

HIGH (16)

Question RO-001: Has the system been tested against out-of-distribution inputs, edge cases, and adversarial perturbations? Article 9(6) and (8) require testing against prior defined metrics and probabilistic thresholds appropriate to the intended purpose. Article 15(5) covers resilience against adversarial examples.

Likelihood	Likely (4)	**Severity**	Major (4)
Residual likelihood	Likely (4)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(6), Art.15

NIST AI RMF: MEASURE 2.5 | ISO/IEC 42001: Annex A.9

Mitigations:

- **Detective** [planned]: Before release, test on a recent sample of the lender's own applicants with amounts converted from DM to euro, plus edge cases (extreme amount and duration) and small input perturbations; the cost-weighted error must not exceed the hold-out value by more than 10 percent.

Recorded by: Mara Lindqvist, Head of Model Risk

Performance metrics not documented for each demographic subgroup

HIGH (16)

Question RO-002: Are accuracy, precision, recall, and calibration metrics documented across all relevant demographic subgroups? Aggregate metrics can mask poor performance for subpopulations. Slice-level evaluation is required for high-risk systems.

Likelihood	Likely (4)	**Severity**	Major (4)
Residual likelihood	Likely (4)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(8), Art.10(2)(f)

NIST AI RMF: MEASURE 2.5 | ISO/IEC 42001: Annex A.9

Mitigations:

- **Detective** [planned]: Report accuracy, precision, recall, calibration error and cost under the dataset's cost matrix (5 for a bad applicant scored good, 1 for the reverse) per subgroup on the hold-out set.

Recorded by: Mara Lindqvist, Head of Model Risk

No performance floor below which the system is taken offline

MEDIUM (9)

Question RO-003: Is there a defined performance floor (minimum acceptable metric threshold) below which the system is taken offline? A defined performance floor ensures degraded models do not remain in production. This is a key operational control.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.9(8), Art.72

NIST AI RMF: MANAGE 1.3 | ISO/IEC 42001: Clause 9.1

Drift not monitored, or no procedure to respond to it

CRITICAL (20)

Question RO-004: Are model degradation scenarios (data drift, concept drift, distribution shift) monitored and have defined response procedures? Models degrade over time as real-world data distributions shift. Post-market monitoring under Article 72 requires detection and response.

Likelihood	Almost certain (5)	**Severity**	Major (4)
Residual likelihood	Almost certain (5)	**Residual severity**	Major (4)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.72

NIST AI RMF: MEASURE 2.4 | ISO/IEC 42001: Clause 9.1

Mitigations:

- **Preventive** [planned]: Retrain on recent applicant data from the lender before release, and do not put the model trained only on the 1994 records into production.
  Recorded by: Mara Lindqvist, Head of Model Risk
- **Detective** [planned]: Compute the population stability index of every input and of the score each month; above 0.25 the lender is alerted and the model is reviewed within 30 days.
  Recorded by: Mara Lindqvist, Head of Model Risk

3.8 Data governance

Dataset provenance not documented

HIGH (12)

Question DG-001: Is the provenance of all training, validation, and test datasets documented (source, collection date, license, version)? Article 10(2) requires data governance practices including documentation of dataset provenance. TraceForge can automate this.

Likelihood	Likely (4)	**Severity**	Moderate (3)
Residual likelihood	Likely (4)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.10(2), Art.10(2)(b)

NIST AI RMF: MAP 2.3 | ISO/IEC 42001: Annex A.7

Accepted: The creator, DOI, licence and file dates are recorded, but when, where and from whom the 1994 records were collected is not published and cannot be recovered. The gap is stated in the limitations section, and the model is retrained on recent lender data before release, so the remaining provenance gap is accepted.
Accepted by: Mara Lindqvist, Head of Model Risk

Data quality not checked before training

MEDIUM (9)

Question DG-003: Are data quality checks (completeness, consistency, accuracy) applied and documented before training and fine-tuning? Article 10(3) requires training, validation and testing data sets to be, to the best extent possible, free of errors and complete in view of the intended purpose. Article 10(2)(c) covers data-preparation processing operations such as cleaning.

Likelihood	Possible (3)	**Severity**	Moderate (3)
Residual likelihood	Possible (3)	**Residual severity**	Moderate (3)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.10(3), Art.10(2)(c)

NIST AI RMF: MAP 2.3 | ISO/IEC 42001: Annex A.7

No retention and deletion schedule for training data and inference logs

LOW (4)

Question DG-004: Is there a data retention and deletion schedule that covers both training data and inference logs? Data retained beyond its purpose creates ongoing legal and privacy risk. GDPR Article 5(1)(e) requires storage limitation.

Likelihood	Unlikely (2)	**Severity**	Minor (2)
Residual likelihood	Unlikely (2)	**Residual severity**	Minor (2)
Source	Question bank	**Regulatory status**	Settled

Article refs: Art.19(1), Art.26(6)

NIST AI RMF: MEASURE 2.10 | ISO/IEC 42001: Annex A.7

Knowledge gap: Answered unknown, so the provider has not judged this risk yet. It is scored at the question's hint, likelihood 2 and severity 2, until it is assessed. Its test requirements are listed in section 5.

4. Residual risk summary

Risk	Inherent	Residual	Mitigations	Decision and rationale
Drift not monitored, or no procedure to respond to it	**20 (critical)**	**20 (critical)**	**2**	**Open**
System processes personal or special category data	**20 (critical)**	**20 (critical)**	**1**	**Open**
Fairness metrics not computed for each protected group	16 (high)	16 (high)	1	Open
Not tested on out-of-distribution, edge-case and adversarial inputs	16 (high)	16 (high)	1	Open

Risk	Inherent	Residual	Mitigations	Decision and rationale
Performance metrics not documented for each demographic subgroup	16 (high)	16 (high)	1	Open
Training data not audited for representation imbalance across protected groups	16 (high)	16 (high)	1	Open
Dataset provenance not documented	12 (high)	12 (high)	0	Accepted: The creator, DOI, licence and file dates are recorded, but when, where and from whom the 1994 records were collected is not published and cannot be recovered. The gap is stated in the limitations section, and the model is retrained on recent lender data before release, so the remaining provenance gap is accepted.
Demographic bias in credit scoring outputs	12 (high)	12 (high)	1	Open
No explanation of the decision logic available to affected people	12 (high)	12 (high)	1	Open
Production performance not monitored for degradation	12 (high)	12 (high)	1	Open
Proxy variables may encode protected characteristics	20 (critical)	12 (high)	2	Open
Review workload too high for meaningful human oversight	12 (high)	12 (high)	0	Open
System errors may harm vulnerable groups disproportionately	12 (high)	12 (high)	1	Open
System may restrict access to rights under the EU Charter of Fundamental Rights	12 (high)	12 (high)	1	Open

Risk	Inherent	Residual	Mitigations	Decision and rationale
System reasoning not interpretable to human reviewers	12 (high)	12 (high)	1	Open
Data quality not checked before training	9 (medium)	9 (medium)	0	Within appetite
Lack of explanation for credit decisions	9 (medium)	9 (medium)	1	Within appetite
No Data Protection Impact Assessment carried out	9 (medium)	9 (medium)	0	Within appetite
No fundamental rights impact assessment before deployment	9 (medium)	9 (medium)	0	Within appetite
No performance floor below which the system is taken offline	9 (medium)	9 (medium)	0	Within appetite
Reviewers not trained on the system's capabilities, limitations and known biases	9 (medium)	9 (medium)	0	Within appetite
Users not told they are interacting with or assessed by an AI system	9 (medium)	9 (medium)	0	Within appetite
Affected people not told of the AI system's role in decisions about them	6 (medium)	6 (medium)	0	Within appetite
Bias tests not repeated at each model update	6 (medium)	6 (medium)	0	Within appetite
Documentation omits capability limitations and known failure modes	9 (medium)	6 (medium)	1	Within appetite
Model uses more personal data than its purpose needs	12 (high)	6 (medium)	1	Within appetite
Personal data in training data not found and redacted or pseudonymised	6 (medium)	6 (medium)	0	Within appetite
No retention and deletion schedule for training data and inference logs	4 (low)	4 (low)	0	Within appetite

5. Article 9(6) to 9(8) test requirements

Risk item	Metric	Threshold	Article
`4d19141a`	**demographic_parity_gap** Risk: Demographic bias in credit scoring outputs. Measure: Largest difference in positive-outcome rate between protected groups. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)

Risk item	Metric	Threshold	Article
`b0a71cc7`	**explanation_request_fulfilment** Risk: Lack of explanation for credit decisions. Measure: Share of explanation requests answered with the decision logic within the set time. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`3fe03c51`	**degradation_alert_time_min** Risk: Production performance not monitored for degradation. Measure: Minutes from an injected performance drop to the alert. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`9a85d48a`	**vulnerable_group_error_gap** Risk: System errors may harm vulnerable groups disproportionately. Measure: Largest difference in error rate between vulnerable groups and other people affected. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`bfc52b79`	**rights_impact_assessment_coverage** Risk: No fundamental rights impact assessment before deployment. Measure: Share of deployment contexts covered by a completed fundamental rights impact assessment. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`a3baa3a9`	**adverse_decision_rate_gap** Risk: System may restrict access to rights under the EU Charter of Fundamental Rights. Measure: Largest difference in adverse-decision rate between groups of affected people. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`52fd5c53`	**ai_role_notice_coverage** Risk: Affected people not told of the AI system's role in decisions about them. Measure: Share of decisions about a person that come with a notice of the AI system's role. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`8f114d3b`	**representation_gap** Risk: Training data not audited for representation imbalance across protected groups. Measure: Largest gap between a protected group's share of the training data and its share of the people the system serves. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`88979633`	**demographic_parity_gap** Risk: Fairness metrics not computed for each protected group. Measure: Largest difference in positive-outcome rate between protected groups. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)

Risk item	Metric	Threshold	Article
`d589bef0`	**proxy_correlation** Risk: Proxy variables may encode protected characteristics. Measure: Strongest correlation between an input feature and a protected characteristic. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`58653409`	**bias_retest_coverage** Risk: Bias tests not repeated at each model update. Measure: Share of model updates released with a documented bias test. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`7112e1e6`	**unprotected_personal_data_rate** Risk: System processes personal or special category data. Measure: Share of personal data records stored or sent without the planned protection, such as encryption, access control or pseudonymisation. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`470efd58`	**dpia_coverage** Risk: No Data Protection Impact Assessment carried out. Measure: Share of processing operations covered by a completed Data Protection Impact Assessment. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`2fd59a99`	**unneeded_personal_data_fields** Risk: Model uses more personal data than its purpose needs. Measure: Number of personal data fields the model uses that its purpose does not need. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`1f588c48`	**ai_disclosure_coverage** Risk: Users not told they are interacting with or assessed by an AI system. Measure: Share of interactions and assessments that tell the person an AI system is involved. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`b4ce87da`	**explanation_request_fulfilment** Risk: No explanation of the decision logic available to affected people. Measure: Share of explanation requests answered with the decision logic within the set time. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`4aec60b2`	**documented_failure_mode_coverage** Risk: Documentation omits capability limitations and known failure modes. Measure: Share of failure modes found in testing that the documentation describes. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)

Risk item	Metric	Threshold	Article
`a29fc827`	**reviewer_training_coverage** Risk: Reviewers not trained on the system's capabilities, limitations and known biases. Measure: Share of human reviewers trained on the system's capabilities, limitations and known biases. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`45d9b8c1`	**review_time_per_case_s** Risk: Review workload too high for meaningful human oversight. Measure: Median seconds a reviewer spends on each case. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`6b73bccd`	**reviewer_explanation_coverage** Risk: System reasoning not interpretable to human reviewers. Measure: Share of outputs shown to reviewers with an explanation, confidence score or supporting evidence. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`c582db0b`	**stress_set_accuracy** Risk: Not tested on out-of-distribution, edge-case and adversarial inputs. Measure: Accuracy on a held-out set of edge-case, out-of-distribution and perturbed inputs. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`6966164c`	**subgroup_performance_gap** Risk: Performance metrics not documented for each demographic subgroup. Measure: Largest difference in accuracy, precision, recall or calibration between demographic subgroups. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`4d9a0d99`	**floor_breach_response_time_min** Risk: No performance floor below which the system is taken offline. Measure: Minutes from a breach of the performance floor to the system being taken offline. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`8b37639c`	**drift_detection_time_h** Risk: Drift not monitored, or no procedure to respond to it. Measure: Hours from an injected data or concept drift to its detection. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`9c0ab3b0`	**dataset_provenance_coverage** Risk: Dataset provenance not documented. Measure: Share of training, validation and test datasets with a documented source,	set by the provider before testing	Art. 9(8)

Risk item	Metric	Threshold	Article
	collection date, licence and version. Set the threshold before testing, appropriate to the intended purpose.		
`8f5d52fb`	**data_quality_check_pass_rate** Risk: Data quality not checked before training. Measure: Share of completeness, consistency and accuracy checks passed before training. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)
`a0daef02`	**retention_schedule_coverage** Risk: No retention and deletion schedule for training data and inference logs. Measure: Share of training data stores and inference logs covered by a retention and deletion schedule. Set the threshold before testing, appropriate to the intended purpose.	set by the provider before testing	Art. 9(8)

6. Audit metadata

Every change to this register is recorded in a SHA-256 hash-chained audit trail stored in `.riskforge/audit.jsonl`. The JSON, PDF and Markdown exports of one register state show the same content digest. The `rmf.exported` entry of this export, recorded after the file was written, holds the content digest and the SHA-256 of this file.

Content digest (SHA-256)	`55c7cb191f3775a63d61c889c6f96d9681ef0753a813fc9916a43bc5fd344827`
RMF schema version	1.2.0
Question bank version	1.0.0
Generated by	RiskForge 2.1.0
Generated at	07 November 2026 18:32 UTC
Chain proof	53 entries of the project audit chain, seq 0 to 52
Receipt	seq 52, entry hash `7f2e623c1dda02516daad6c4cb0e61e99d0da8d35a37631595dc4b1de17b803d`
Signatures	Unsigned
Sign-offs	None recorded

Change log

Entries of the chain proof for this system and for the project.

Seq	Time (UTC)	Event	Actor
0	2026-11-07 18:32	system.created	cli
1	2026-11-07 18:32	system.classified	cli
2	2026-11-07 18:32	register.created	Mara Lindqvist
3	2026-11-07 18:32	risk_item.created	Mara Lindqvist
4	2026-11-07 18:32	risk_item.created	Mara Lindqvist
5	2026-11-07 18:32	risk_item.created	Mara Lindqvist
6	2026-11-07 18:32	risk_item.created	Mara Lindqvist
7	2026-11-07 18:32	risk_item.created	Mara Lindqvist
8	2026-11-07 18:32	risk_item.created	Mara Lindqvist
9	2026-11-07 18:32	risk_item.created	Mara Lindqvist
10	2026-11-07 18:32	risk_item.created	Mara Lindqvist
11	2026-11-07 18:32	risk_item.created	Mara Lindqvist
12	2026-11-07 18:32	risk_item.created	Mara Lindqvist
13	2026-11-07 18:32	risk_item.created	Mara Lindqvist
14	2026-11-07 18:32	risk_item.created	Mara Lindqvist
15	2026-11-07 18:32	risk_item.created	Mara Lindqvist
16	2026-11-07 18:32	risk_item.created	Mara Lindqvist
17	2026-11-07 18:32	risk_item.created	Mara Lindqvist
18	2026-11-07 18:32	risk_item.created	Mara Lindqvist
19	2026-11-07 18:32	risk_item.created	Mara Lindqvist
20	2026-11-07 18:32	risk_item.created	Mara Lindqvist
21	2026-11-07 18:32	risk_item.created	Mara Lindqvist
22	2026-11-07 18:32	risk_item.created	Mara Lindqvist
23	2026-11-07 18:32	risk_item.created	Mara Lindqvist
24	2026-11-07 18:32	risk_item.created	Mara Lindqvist
25	2026-11-07 18:32	risk_item.created	Mara Lindqvist
26	2026-11-07 18:32	risk_item.created	Mara Lindqvist
27	2026-11-07 18:32	risk_item.created	Mara Lindqvist
28	2026-11-07 18:32	risk_item.created	Mara Lindqvist
29	2026-11-07 18:32	risk_item.created	Mara Lindqvist

Seq	Time (UTC)	Event	Actor
30	2026-11-07 18:32	risk_item.created	Mara Lindqvist
31	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
32	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
33	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
34	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
35	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
36	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
37	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
38	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
39	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
40	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
41	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
42	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
43	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
44	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
45	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
46	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
47	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
48	2026-11-07 18:32	mitigation.added	Mara Lindqvist, Head of Model Risk
49	2026-11-07 18:32	risk.accepted	Mara Lindqvist, Head of Model Risk
50	2026-11-07 18:32	tests.generated	cli
51	2026-11-07 18:32	rmf.exported	cli
52	2026-11-07 18:32	rmf.exported	cli

Verify integrity at any time: `riskforge verify`. Check the JSON export of this register state with `riskforge verify --file <JSON export>`: it carries the content digest above.